

Guía Metodológica para la Encuesta de Métricas de Ciberseguridad

1. Propósito general

Esta guía acompaña al modelo de encuesta y explica cómo diseñar, administrar, interpretar y mantener en el tiempo una encuesta sobre métricas de ciberseguridad inspirada en NIST SP 800-55 (volúmenes 1 y 2) y alineada con el contexto regulatorio español (ENS, NIS2, RGPD y normativa sectorial).

El objetivo no es solo recopilar datos, sino sentar las bases de un programa de medición coherente que vincule indicadores con decisiones de negocio, riesgos y resiliencia nacional.

2. Fundamento conceptual

La encuesta se estructura en torno a los principios de NIST SP 800-55:

- Las métricas se derivan de objetivos y decisiones, no de la disponibilidad caprichosa de datos.
- La combinación de métricas de eficacia, eficiencia, impacto, cumplimiento y madurez proporciona una visión más rica que cualquier indicador aislado.
- La calidad de los datos y la consistencia de las definiciones son condiciones necesarias para que las métricas no degeneren en decoración de PowerPoint.

En paralelo, se ha tenido en cuenta la evolución del marco europeo (NIS2) y del Esquema Nacional de Seguridad, así como la práctica real de organismos como INCIBE y CCN-CERT en la generación de estadísticas agregadas.

3. Población objetivo y segmentación

La encuesta está dirigida a organizaciones con un mínimo de formalización en materia de ciberseguridad, en particular aquellas que:

- Están o podrían estar sujetas a NIS2 o al ENS.
- Son operadores de servicios esenciales o importantes.
- Mantienen infraestructuras críticas o servicios digitales de alto impacto.

Se recomienda segmentar los resultados al menos por:

- Sector (energía, salud, financiero, transporte, administración pública, servicios digitales, etc.).
- Tamaño de la organización (por tramos de empleados y facturación).
- Rol del encuestado (CISO, CIO, Dirección de Riesgos, Dirección General, etc.).

4. Diseño del cuestionario

La encuesta combina preguntas cerradas (para facilitar el análisis estadístico) con preguntas abiertas (para capturar matices, ironías y la creatividad inagotable de la realidad organizativa).

Las secciones cubren:

- Gobernanza del programa de métricas.
- Alcance y tipología de indicadores.

- Métricas de incidentes y amenazas.
- Controles técnicos y Zero Trust.
- Cumplimiento normativo.
- Capacidad organizativa y cultura.
- Impacto, riesgo y resiliencia.
- Inversión y ROI.
- Alineamiento con marcos NIST/ENS/NIS2.

Cada sección está pensada para mapearse tanto a requisitos normativos como a buenas prácticas de medición, lo que permite posteriores análisis de brecha (gap analysis) y priorización.

5. Administración de la encuesta

5.1. Modalidad

Se recomienda la administración online (herramienta de encuesta o formulario web) con autenticación básica para evitar respuestas duplicadas, pero sin introducir fricciones excesivas.

5.2. Duración

La encuesta está diseñada para completarse en aproximadamente 25-35 minutos por parte de un responsable con conocimiento razonable de la organización.

5.3. Instrucciones al encuestado

- Responder en nombre de la organización, no solo del área de TI.
- Coordinarse internamente, si es necesario, para aquellos bloques que requieran información específica (finanzas, riesgos, operaciones).
- Indicar con honestidad el estado actual, no el estado aspiracional que aparecerá en el próximo plan estratégico.

5.4. Anonimato y confidencialidad

Para maximizar la sinceridad de las respuestas, se recomienda:

- Anonimizar los resultados para análisis agregados.
- No utilizar los datos para auditoría individual de organizaciones, salvo acuerdo explícito.

6. Escalas de respuesta y codificación

La mayoría de las preguntas cerradas utilizan escalas ordinales o nominales fáciles de codificar:

- Escalas de frecuencia (sí, parcialmente, no, etc.).
- Escalas de madurez (inexistente, ad hoc, definido, gestionado, optimizado).
- Escalas de impacto (bajo, medio, alto).

Se recomienda asignar valores numéricos a estas escalas para facilitar la construcción de índices (por ejemplo, 0 a 3 o 0 a 4), documentando cuidadosamente la codificación.

7. Calidad de datos

Para aumentar la calidad de los datos:

- Habilitar validaciones básicas (por ejemplo, evitar inconsistencias lógicas flagrantes).
- Incluir instrucciones contextuales en preguntas especialmente sensibles.
- Permitir que el encuestado marque "no aplica" o "no sabe" en lugar de forzar respuestas ficticias.

Se sugiere revisar una muestra de respuestas para detectar patrones extraños (por ejemplo, respuestas idénticas en todos los ítems, o combinaciones incoherentes) y decidir si deben excluirse del análisis agregado.

8. Análisis de resultados

El análisis puede abordarse en varias capas:

1. Descriptivo básico: porcentajes de adopción de determinadas prácticas, distribución de niveles de madurez, etc.
2. Comparativo: diferencias entre sectores, tamaños de empresa, o rol del encuestado.
3. Correlacional: análisis exploratorio de relaciones entre indicadores (por ejemplo, relación entre presencia de programa formal de métricas y cálculo de ROI, o entre inversión y ciertos niveles de incidentes).
4. Construcción de índices: derivar un Índice Global de Madurez (IGM) a partir de subconjuntos de preguntas ponderadas.

9. Actualización periódica y tendencias

La encuesta está diseñada para poder repetirse de forma periódica (por ejemplo, anual o bienal) y así poder observar tendencias en el tiempo.

Es recomendable mantener el núcleo de preguntas estable y añadir módulos específicos para temas emergentes (p. ej. criptografía poscuántica, IA generativa, etc.), evitando reescribir todo el instrumento cada año.

10. Limitaciones y sesgos

Como todo instrumento basado en autodeclaración, la encuesta está sujeta a:

- Sesgo de deseabilidad social (tendencia a exagerar la madurez).
- Sesgo de supervivencia (tienden a responder las organizaciones más sensibilizadas).
- Sesgos internos (visión de TI vs. visión de negocio).

La recomendación metodológica es tratar la encuesta como una pieza más del puzzle: complementarla con datos observacionales (incidentes, auditorías, informes) y, sobre todo, con una sana dosis de escepticismo profesional.